

Information Security Policy

Version 6.0 · Effective 1 April 2026 · Aligned with ISO/IEC 27001:2022 and SOC 2 Type II

Topic	Requirement
Overview	Version 6.0 · Effective 1 April 2026 · Aligned with ISO/IEC 27001:2022 and SOC 2 Type II
Data classification - Public	Examples: Website, published blogs; Handling: No restriction
Data classification - Internal	Examples: Handbook, org charts; Handling: Company systems only
Data classification - Confidential	Examples: Source code, financials, contracts; Handling: Need-to-know, encrypted at rest
Data classification - Restricted	Examples: Client PII, payroll, credentials; Handling: Named access, MFA, audit logged, never on personal devices
Access control	SSO with MFA is mandatory for all systems.
Access control	Least privilege. Access is reviewed quarterly by system owners.
Access control	Joiner/mover/leaver requests go through the IT portal. Leaver access is revoked within 4 hours of the last working day.
Devices	Company-managed laptops only, with full-disk encryption, EDR agent and auto-lock at 5 minutes.
Devices	No USB mass storage. Personal phones may access email or Slack only through the MDM container.
Passwords and secrets	Minimum 14 characters. Use the company password manager.
Passwords and secrets	Secrets live only in the vault, never in code, tickets or chat.
Client data	Client data stays in client-approved environments.
Client data	Production data must not be copied to laptops or used in non-prod without masking.
Acceptable AI use	Approved AI tools only. Confidential and restricted data must never be pasted into unapproved AI services.
Incident reporting	Report suspected incidents to security@nimbus.example or #sec-incident within 1 hour . The security team triages within 4 hours. Breaches affecting personal data are notified within 72 hours where the law requires it (e.g. GDPR, DPDP Act 2023).
Training	Security awareness at joining and annually, plus quarterly phishing simulations. Failing a simulation twice triggers a refresher.
Purpose and scope	Protect the confidentiality, integrity and availability of Nimbus and client information. It applies to all people, devices, systems and data. This includes SaaS tools and client-provided environments.
Roles	CISO: owns the policy; reports risk quarterly to the leadership team.
Roles	System owners: approve access, run quarterly reviews, keep asset inventories.
Roles	Employees: follow the controls and report incidents.
Roles	Managers: make sure leavers and movers are processed the same day.
Controls summary - Patching	Standard: Critical within 7 days, high within 30 days
Controls summary - Backups	Standard: Daily, encrypted, restore test quarterly
Controls summary - Logging	Standard: Security logs retained 12 months
Controls summary - Vulnerability scans	Standard: Weekly external, monthly internal
Controls summary - Penetration test	Standard: Annual third-party + after major releases
Controls summary - Vendor security	Standard: Security questionnaire + DPA before onboarding
Clean desk and screen	Lock your screen whenever you step away. Printouts of confidential data go in the shred bin. Nothing confidential is left on whiteboards.
Incident examples to report	Clicking a phishing link.
Incident examples to report	Losing a laptop or phone.
Incident examples to report	Sending client data to the wrong recipient.
Incident examples to report	Discovering exposed credentials in a repository.

Topic	Requirement
Incident examples to report	Unusual MFA prompts.
Incident severity levels	SEV1: client data exposure. Leadership is informed within 2 hours.
Incident severity levels	SEV2: internal confidential data exposure.
Incident severity levels	SEV3: policy breach with no exposure.
Incident severity levels	Every incident gets a post-incident review within 5 business days.
Exceptions	Exceptions are requested via the IT portal and need CISO approval. They are time-bound, 90 days at most.
FAQs	Can I use my personal laptop in an emergency? No. Contact IT for a loaner.
FAQs	Can I install software? Only from the company catalogue. Other software needs a request.
Revision history	6.0 (2026): Acceptable AI use section added.
Revision history	5.0 (2025): Moved to ISO 27001:2022 controls.